

TCP and UDP

4/15/26 8:51 PM

Summary:

- **TCP:** Reliable but visible (handshake + flags). Use for detecting scans, C2, and data exfil.
- **UDP:** Fast and lightweight. Use for detecting tunneling, amplification, and fast exfil.
- **Detection workflow:**
 1. Capture traffic (**Wireshark / tcpdump**).
 2. Filter for anomalies (**SYN** floods, unusual ports, flag patterns).
 3. Correlate with host artifacts (processes, logs).
 4. Investigate root cause and block.

Common Commands:

- `tcpdump -nn -r file.pcap — read PCAP.`
- `tcpdump -nn -r file.pcap 'tcp[tcpflags] == tcp-syn' — SYN packets only.`
- `tcpdump -nn -r file.pcap 'src host IP' | cut ... | sort | uniq -c — analyze ports and counts.`

These basics let you quickly spot Layer 4 attacks in real incidents (e.g., SYN scans, C2 over common ports, or UDP tunneling).

1. TCP vs UDP Basics

TCP (Transmission Control Protocol):

- **Connection-oriented** — establishes reliable connection before sending data.
- Uses **three-way handshake**: SYN → SYN-ACK → ACK.
- Guarantees delivery with sequence/acknowledgment numbers.
- Higher overhead, slower, but reliable (used for web, email, file transfers).

UDP (User Datagram Protocol):

- **Connectionless** — sends data without handshake or guaranteed delivery.
- Very low overhead, fast (used for DNS, NTP, streaming, VoIP).
- No sequence numbers or acknowledgments — “fire and forget”.

Security relevance:

- **TCP** is commonly abused for scanning, C2, and data exfiltration (visible handshake + flags).
- **UDP** is abused for amplification attacks, DNS tunneling, and fast exfil (harder to track because no handshake).

Key takeaway: Know which applications use **TCP** vs **UDP** by default. Anomalies (e.g., DNS over TCP) are often suspicious.

2. TCP Flags and Handshake

TCP Flags (important for detection):

- **SYN:** Start connection.
- **SYN-ACK:** Server response.
- **ACK:** Acknowledgment.
- **RST:** Reset/abort connection.
- **FIN:** Graceful close.

Normal Three-Way Handshake:

1. Client sends **SYN**.
2. Server replies **SYN-ACK**.
3. Client sends **ACK**.

Inspecting Flags in tcpdump:

Bash

```
tcpdump -nn -r file.pcap | more
```

Look for flags in square brackets: [S], [S.], [.].

Example command to see only SYN-ACK packets:

Bash

```
tcpdump -nn -r file.pcap 'tcp[tcpflags] == (tcp-syn|tcp-ack)'
```

Security relevance:

- **SYN scan** (half-open scan): Attacker sends many **SYN** packets but never completes handshake (no final ACK).
- Detection: High volume of **SYN** from one source with few/no **SYN-ACK** replies.

Demo insight:

- Normal web traffic: Clear handshake + TLS negotiation.
- Malicious: Many **SYN** packets to multiple IPs/ports without completing handshake → **SYN scanning**.

3. Ports and Ephemeral Ports

Ports:

- 16-bit numbers (0–65535).
- Well-known ports (0–1023): HTTP=80, HTTPS=443, DNS=53.
- Any port can host any service — attackers often use common ports (e.g., 443) to blend in.

Ephemeral ports:

- High-range ports (usually 49152–65535) used by clients for temporary connections.
- Client uses a new ephemeral port for each conversation.

Detection:

- Normal: Client uses many different ephemeral ports with low packet count per port.
- Suspicious: One ephemeral port with massive packet count → possible C2 beacon or long-lived connection.

Example commands (from demos):

Bash

```
tcpdump -nn -r file.pcap 'src host 192.168.218.131' | cut -f 3 -d " " | sort | uniq -c | sort -n
```

→ Shows ephemeral ports used by a client.

Bash

```
tcpdump -nn -r file.pcap 'src host 192.168.218.131' | cut -f 5 -d " " | cut -f 5 -d "." | sort | uniq -c | sort -n
```

→ Shows destination ports (services contacted).

Key takeaway: Look for unusual port usage or one ephemeral port dominating traffic.

4. Malicious Traffic Patterns (TCP/UDP)

TCP Anomalies:

- **SYN scan:** Many **SYN** packets, few/no **SYN-ACK** replies.
 - Command to detect:

Bash

```
tcpdump -nn -r syn-scan.pcap 'tcp[tcpflags] == tcp-syn' | cut -f 3 -d " " | cut -f 1-4 -d "." | sort | uniq -c | sort -n
```
 - Look for one source sending thousands of **SYN** to many IPs/ports.

UDP Anomalies:

- DNS over TCP (unusual — normally UDP).
- High-volume UDP to amplification targets (e.g., NTP, DNS).
- Unusual protocols on unexpected ports.

General Detection Tips:

- Baseline normal traffic (ports, flags, volume per port).
- Look for scripted behavior (same pattern repeated across many targets).
- Correlate with host logs (e.g., process that generated the traffic).

Demo insight (Malicious Traffic):

- SYN scanning: Single IP sending 143,738 SYN packets.
- Scanned ports: Many ports attempted 128 or 256 times.
- Internal IPs responding on unusual ports (135, 139, 445, 8080, 5357) → investigate as potential lateral movement.

Key takeaway: Understand normal protocol behavior (handshake, ports, flags). Anomalies (scans, unusual flags, high volume on one port) are strong indicators of malicious activity.

TCP DUMP Commands

Core Purpose: Capture, save, read, and filter live or saved network traffic for analysis.

Basic Commands (usable in any investigation):

```
sudo tcpdump          # Start live capture on default interface
sudo tcpdump -i eth0  # Capture on specific interface
sudo tcpdump -c 50    # Capture only 50 packets then stop
sudo tcpdump -w capture.pcap # Write packets to file for later analysis
sudo tcpdump -r capture.pcap # Read and display from saved pcap file
```

Common Filters (apply to live or saved captures):

```
sudo tcpdump host 192.168.1.100 # Traffic to/from a specific IP
sudo tcpdump port 80            # Traffic on a specific port (HTTP example)
sudo tcpdump port 22           # Traffic on SSH port
sudo tcpdump tcp               # Only TCP packets
sudo tcpdump udp               # Only UDP packets
sudo tcpdump icmp              # Only ICMP (ping) packets
```

Verbose & Readable Output:

```
sudo tcpdump -vv          # Very verbose output (more packet details)
sudo tcpdump -A           # Show packet data in ASCII (human readable)
sudo tcpdump -X           # Show packet data in hex + ASCII
sudo tcpdump -nn          # Show IPs and ports as numbers only (no DNS resolution)
```

tcpdump + grep for Targeted Network Analysis (very useful for quick searches):

```
sudo tcpdump -r capture.pcap -nn -l | grep "HTTP"      # Find HTTP requests/responses
sudo tcpdump -r capture.pcap -nn -l | grep "POST"      # Find POST requests (possible exfil or C2)
sudo tcpdump -r capture.pcap -nn -l | grep "password"  # Search for plaintext passwords
sudo tcpdump -r capture.pcap -nn -l | grep "User-Agent" # Spot unusual or suspicious User-Agents
sudo tcpdump -r capture.pcap -nn -l | grep -E "ru|cn|tk" # Find suspicious country-code domains
sudo tcpdump -r capture.pcap -nn -l | grep "SYN"       # Find SYN packets (scans or floods)
```

Real-world Usage Tips:

- Always use `-nn` when piping to `grep` to avoid slow DNS lookups.
- Use `-l` (line-buffered) so `grep` processes output in real time.
- Combine with filters: `sudo tcpdump -r capture.pcap host 192.168.1.100 and port 80 -nn -l | grep "POST"`